

Information Security Questionnaire

	Required	Total Questions	Total Critical Risk
Security Fundamentals Overview	Yes	17	0
Data	Yes	41	0
Internet Connectivity	Yes	24	0
Security Architecture	Yes	8	0
Technology-Specific Controls	Yes	20	0
Total		110	0

Total High Risk	Total Medium Risk	Total Low Risk	Total Information Required	Total Unanswered
1	0	16	0	0
3	0	36	0	2
0	0	12	0	12
0	0	8	0	0
0	0	20	0	0
4	0	48	0	14

Risk Assessment Questions

Answer

Requirement (Auto Fill)

Security Fundamentals	COMPULSORY	Answer Section '1. Fundamentals'
Does the contracted activity involve the collecting, hosting, storing, transmitting, destroying, altering, reading or otherwise processing of Restricted or Personal Data	Yes	Answer Section '2. Data' & Section '8. Security Architecture'
Does the contracted activity involve the processing of payment data	No	
Is the contracted activity/service internet connected (eg websites, mobile applications)	Yes	Answer Section '4. Internet Connected'
Is the supplier performing development activities on behalf	No	
Does the contracted activity require remote access to systems/network	No	

Technology-Specific Controls

Complete Yes or No

Cloud Services / Cloud Hosted Services	Yes	Cloud Security
AI/ML Services (Artificial intelligence / Machine Learning)	Yes	AI/ML Risk Management
OT/ICS Services	No	OT/ICS Security
API Development / Integration	No	API Security Controls
Containerized Applications	No	Container Security Controls
Professional Services / Consultancy	No	Basic Governance + Third Party Risk Management
Hardware Manufacturing / Supply	No	Supply Chain Risk Controls
Other	No	
Answer Section '7. Technology-Specific Controls'		

Information Security Fundamentals - Questions	Answer	Risk Flag	Free Text Narrative	Action Plan
Do you hold any external Information Security accreditations (such as ISO27001 or SAS70)	Yes	Low	Teramot is currently in the final stage of its SOC 2 Type I compliance program. - The SOC 2 Type I audit has been completed, and the engagement is currently in the final approval / draft validation phase with the auditing firm. - Formal issuance of the SOC 2 Type I report is expected within the next two weeks, subject only to final auditor approval. - Immediately following the issuance of SOC 2 Type I, Teramot will enter the SOC 2 Type II observation period, as part of its continuous compliance roadmap. In parallel, Teramot has initiated its ISO/IEC 27001 implementation program: - An Information Security Management System (ISMS) has been formally established. - Core ISO 27001 controls are already implemented and operating, including: - Information Security Policies - Risk Assessment and Risk Treatment processes - Asset management and access control - Incident management processes - Security awareness and training - Documented evidence for multiple ISO/IEC 27001 controls already exists, and additional evidence is being continuously collected as part of the ISMS lifecycle. - Formal ISO/IEC 27001 certification is planned following the SOC 2 Type I completion. Teramot's compliance strategy is designed around internationally recognized frameworks, ensuring alignment with: - SOC 2 Trust Services Criteria (Security, Availability, Confidentiality) - ISO/IEC 27001 Annex A controls - GDPR-aligned data protection principles where applicable Upon request, Teramot can provide: - SOC 2 Type I draft / attestation status confirmation - ISMS documentation and policy evidence - Compliance roadmap covering SOC 2 Type II and ISO/IEC 27001 certification timelines	Copy of Accreditations Required
Do you employ security qualified people (CISP, CISM, etc)	Yes	Low	Teramot employs security-qualified professionals with formal training and active specialization in: - Information Security - Risk Management - Compliance (ISO/IEC 27001, SOC 2) - Cloud Security (AWS) Certifications and credentials include formal security training, ISO 27001 implementation experience, and ongoing certification paths (e.g., CISP-oriented roles). A list of roles, qualifications, and security responsibilities can be provided if required.	
Do you perform background/credit checks on employees	Yes	Low	Teramot performs background verification during the recruitment process, including: - Identity verification - Employment history validation - Professional reference checks - Criminal background checks, in accordance with applicable local regulations - Psychological assessments, aimed at evaluating suitability for roles involving access to sensitive information and systems	
Do all employees, permanent and temporary, and contractors sign contracts that contain confidentiality/non-disclosure clauses?	Yes	Low	All employees and contractors are required to sign Confidentiality and Non-Disclosure Agreements (NDA) as part of their contractual obligations.	
Do you have a corporate information security policy (covering for example clear desk, information classification and handling, internet and e-mail usage)	Yes	Low	Teramot maintains a formal Information Security Policy (ISP) Link to Compliance and Security Hub with Policy	
Do you have a corporate data protection policy/guidelines for the handling or use of personal data?	Yes	Low	Teramot maintains a formal Data Management Policy Link to Compliance and Security Hub with Policy	
Do you have a programme in place to ensure compliance with the GDPR (General Data Protection Regulation)?	Yes	Low	Although Teramot is based outside the EU, it is progressively aligning its security and data protection controls with GDPR requirements for clients that require GDPR compliance. Due to the significant overlap between GDPR and the SOC 2 framework, many GDPR-related principles such as data minimization, purpose limitation, access control, and incident notification are already largely addressed through existing and in-progress SOC 2 controls, placing Teramot in an advanced state of readiness.	
Do you ensure that all employees have read and understood the appropriate information security and data protection policies?	Yes	Low	All employees are required to: - Acknowledge and comply with the Information Security Policy - Comply with the Data Protection Policy Policy awareness is part of onboarding and ongoing compliance processes.	
Are all staff provided with annual information security training and annual data protection training?	Yes	Low	Teramot conducts regular security awareness and data protection training, including: - Secure handling of information - Incident awareness - Phishing and social engineering risks - Data protection responsibilities Training is conducted at least annually and reinforced as needed.	
Do you have an information security incident management process	Yes	Low	Teramot operates a formal incident management process aligned with SOC 2 and ISO/IEC 27001 principles, leveraging AWS-native security services including CloudTrail, GuardDuty, Security Hub, CloudWatch alarms, and AWS Inspector for detection, alerting, triage, containment, and post-incident review.	
Do you perform an Information Security risk assessment, on at least an annual basis	Yes	Low	Teramot performs periodic risk assessments based on SOC 2 and ISO/IEC 27001 methodologies, incorporating AWS risk signals such as Inspector findings, GuardDuty detections, Security Hub posture scores, and infrastructure configuration reviews, with documented risk treatment and remediation tracking.	
Are any of the services relating to the contracted operation outsourced or subcontracted to a third-party and will these third parties access data?	No	Low		
Will any data be transferred or accessed from outside Europe (i.e. Are ANY of your Data Centres and Servers located outside Europe? Are any 3rd party subcontractors you use or their personnel located outside Europe? If yes, please provide details in Column H.	Yes	High	Teramot operates from Argentina, therefore data may be accessed from outside Europe strictly for service delivery purposes. Access is: - Role-based - Authenticated - Logged - Encrypted in transit No unauthorized international transfers occur.	
Have you had any data breaches or incidents in the last 12 months?	No	Low	Teramot has not experienced any data breaches or security incidents involving client data in the past 12 months.	
Do you provide an Incident Reporting mechanism that will inform of a Breach or threatened breach of its data?	Yes	Low	Teramot provides an automated incident reporting mechanism based on AWS-native eventing and alerting. Security-relevant events detected via Amazon GuardDuty, AWS Security Hub, CloudWatch Alarms, and AWS Inspector are centralized and routed through Amazon EventBridge, which triggers SNS notifications. Specific notification channels can be configured (e.g., dedicated SNS topic and email distribution) to ensure timely notification of confirmed or suspected security incidents affecting data, similar to the existing security alerting pipeline used for internal security notifications.	
Are your premises secure from unauthorised access?	Yes	Low	Physical and operational security controls include: - Restricted access to work environments - Secure remote work practices	
Do you contract external parties to conduct independent reviews of your information security practices?	Yes	Low	Teramot engages external independent security assessments, including penetration testing conducted by Faraday Security. Identified findings, risk ratings, and remediation actions are formally documented. Periodic reports, along with remediation evidence and applied fixes, are shared via secure communication (email) and supported by internal documentation repositories. Link to document	

Data Management - Questions

Will data be stored in a shared environment?	Yes	High	Data is stored in logically isolated environments within AWS, using tenant separation, IAM boundaries, security groups, and encryption. No physical co-mingling. Isolation is enforced at the application, network, and IAM layers.
Will data be stored or processed on laptops?	No	Low	Data is accessed via controlled cloud services only and is not stored or persistently processed on employee laptops.
Will data be transmitted between other locations/3rd parties?	No	Low	data is processed exclusively within Teramot-controlled cloud environments.
Will data be stored or processed on Removable Media?	No	Low	Use of removable media for data is prohibited.
Do you lock down USB ports?	Yes	Low	USB ports are restricted via OS-level policies and endpoint security controls, preventing unauthorized data transfer.
Do you have any controls in place to prevent data leakage via Internet sites e.g (Drop Box, Gmail)?	No	High	No (currently). Explicit DLP tooling is not yet deployed; however, access controls, least privilege IAM, encrypted channels, and policy enforcement significantly reduce leakage risk. DLP controls are under evaluation as part of the compliance roadmap.
Do you have an information classification policy/scheme that defines the security controls that should be applied to each different classification level?	Yes	Low	Teramot maintains an Information Classification Policy defining Public, Internal, Confidential, and Restricted data, with corresponding handling and protection requirements. Link to Compliance Hub
Do you provide guidance to your employees on how to handle and transfer 's information securely?	Yes	Low	Secure handling and transfer requirements are defined in internal security policies and employee awareness documentation.
Will User Access Processes be put in place so that 's data is accessed on a need-to-know basis?	Yes	Low	Access is enforced using least privilege, role-based access control (RBAC), and IAM policies.
Will all accounts accessing 's data be assigned to individuals (as opposed to being shared by multiple users)?	Yes	Low	All access is tied to individual, uniquely identifiable accounts. No shared user accounts are permitted.
Do you have file encryption capability to ensure that sensitive data is encrypted at rest while in your possession?	Yes	Low	Data is encrypted at rest using AWS-managed encryption (KMS) at storage, database, and volume levels.
Do you keep a Data Asset Register?	Yes	Low	Data assets are documented and tracked as part of ISMS and compliance documentation.
Are security controls in place to prevent unauthorised physical access to data (both on-site and offsite)?	Yes	Low	Physical access is restricted to authorized personnel; production systems are hosted in AWS-managed data centers.
Is Anti-Virus deployed to all workstations and servers? Windows Defender y MalwareBytes	Yes	Low	BitDefender are deployed on endpoints and servers where applicable.
Do you have anti-malware controls in place?	Yes	Low	Teramot uses Bitdefender Endpoint Security for workstations and endpoints, and AWS-native security services for servers and cloud workloads, including ECR, EKS, and ECR, leveraging AWS Inspector, GuardDuty, and image scanning to detect malware, vulnerabilities, and malicious activity across infrastructure and container images.
Do you encrypt laptop hard drives?	Yes	Low	Full-disk encryption is enforced (e.g., BitLocker / OS-native encryption).
Do you operate a media destruction policy?	Yes	Low	Media destruction procedures are defined and documented as part of security policies.
Are there vulnerability assessment and patch management processes?	Yes	Low	Vulnerability management is performed using AWS Inspector, dependency scanning, and regular patch cycles, with tracked remediation.
Are log files created and archived?	Yes	Low	Logs are centralized via CloudWatch and CloudTrail, with defined retention policies for 365 days (1 year).
Are access logs created showing successful and unsuccessful logins?	Yes	Low	Authentication and access logs are enabled and retained for 365 days(1 year) per security policy.
Is 2 factor authentication in place for critical access rights including access to restricted data?	Yes	Low	Multi-Factor Authentication (MFA) is enforced for privileged and sensitive access.
Is there a formal user provisioning (registration and de-registration) procedure in place	Yes	Low	User provisioning and de-provisioning are documented and enforced through IAM and internal procedures.
Will data be retrievable when the contract has ended?	Yes	Low	Data can be securely exported or returned according to contractual requirements.
Are log files enabled and protected to prevent unauthorised deletion or modification?	Yes	Low	Logs are protected using AWS IAM controls and immutable storage configurations.

Incident Response - Questions

Do you maintain a documented and tested Incident Response Plan (IRP)?	Yes	Low	A formal Incident Response Plan aligned with SOC 2 exists and is periodically tested.
Are incidents categorized based on severity and impact according to a formal taxonomy?	Yes	Low	Incidents are classified by severity and business impact.
Does the supplier have mechanisms to detect, analyze, and prioritize security incidents in near real-time?	Yes	Low	Detection uses GuardDuty, Security Hub, CloudWatch, and EventBridge.
Are there defined Service Level Agreements (SLAs) for incident response times, including customer notification? Detail your response	Yes	Low	Internal SLAs define response, escalation, and notification timelines.
Is forensic evidence preserved appropriately during security incident investigations?	Yes	Low	Logs, snapshots, and audit trails are preserved following forensic best practices.
Are periodic incident response exercises (tabletop, simulation, red team) conducted to validate readiness?	Yes	Low	
Is the incident response process continuously improved based on lessons learned from incidents and exercises?	Yes	Low	
Is there a mechanism to coordinate incident reporting with regulatory authorities where required (e.g., data breach notification laws)?	Yes	Low	

Privacy and Data Sovereignty Compliance - Questions

Are mechanisms in place to allow individuals to exercise privacy rights (e.g., access, correction, deletion)?	Yes	Low	Requests are handled through defined internal procedures.
Is data minimization practiced by limiting the collection and retention of personal data to what is strictly necessary?	Yes	Low	Collection and retention are limited to operational necessity.
Are privacy risks assessed and documented during the development of new products, services, or systems (e.g., Privacy Impact Assessments)?	Yes	Low	
Is personal data transferred or processed across jurisdictions with consideration for applicable data sovereignty requirements?	Yes	Low	
Are third parties that process personal data required to adhere to the supplier's privacy standards and contractual obligations?	No	High	No. data is not processed by third parties.
Is personal data protected through encryption, pseudonymization, or anonymization where appropriate?	Yes	Low	
Are privacy incidents reported, managed, and remediated in coordination with security incident response processes?	Yes	Low	Privacy incidents are handled within the unified incident response framework.

External Connectivity - Questions

External Connectivity - Questions	Answer	Risk Flag	Free Text Narrative
Does the application/infrastructure undergo a regular independent Penetration Test AND Vulnerability Assessment?	Yes	Low	Independent penetration tests are performed periodically (at least annually) by external providers (e.g., Faraday Security), complemented by continuous vulnerability scanning using AWS Inspector and dependency scanning. The most recent penetration test and vulnerability assessment were conducted within the last audit cycle, with findings tracked and remediated.
Do you operate a software QA process which captures common application vulnerabilities (such as SANS or OWASP)?	Yes	Low	Teramot operates a secure SDLC and QA process aligned with OWASP Top 10 and SANS principles, incorporating code reviews, dependency scanning, and security checks during development and deployment. Procedures are documented as part of internal engineering and security guidelines.
Do you harden externally accessible systems, in line with independent guidance (such as CIS or NIST)?	Yes	Low	Externally accessible systems are hardened using CIS Benchmarks and NIST-aligned best practices, including hardened AMIs, restricted security groups, least-privilege IAM roles, network segmentation, and secure baseline configurations.
Are administration environments accessed via two factor authentication?	Yes	Low	Administrative access requires Multi-Factor Authentication (MFA) enforced via AWS IAM and identity providers, covering cloud consoles and privileged systems.
Are detailed web logs and error logs generated and retained for at least a year?	Yes	Low	Administrative access requires Multi-Factor Authentication (MFA) enforced via AWS IAM and identity providers, covering cloud consoles and privileged systems.
Are websites monitored for availability?	Yes	Low	Website availability is monitored using CloudWatch health checks and synthetic monitoring, with alerting via SNS.
Are websites monitored for configuration changes	Yes	Low	Configuration changes are monitored through AWS CloudTrail, Infrastructure-as-Code controls, and change auditing, enabling detection of unauthorized or unexpected modifications.
For externally facing applications are users provided with a mechanism to select their own password?	Yes	Low	Externally facing applications provide secure user-managed password selection, enforcing password complexity and lifecycle policies.
Are all passwords and authentication tokens send over an encrypted connection? (e.g SSL)	Yes	Low	All authentication credentials and tokens are transmitted exclusively over TLS-encrypted connections (HTTPS).
Does the service provide with a mechanism to review user access rights? E.g. provide a list of user accounts and their current access?	Yes	Low	Teramot can provide with user access listings and role assignments upon request, supporting access review and audit requirements.
Do you have anti-malware controls in place? Windows Defender y MalwareBytes	Yes	Low	Bitdefender Endpoint Security is used for workstations, while AWS-native security services protect servers and workloads (EC2, ECS, ECR), including Inspector, GuardDuty, and container image scanning.
Do you have intrusion detection technology in place?	Yes	Low	Intrusion detection is implemented using AWS GuardDuty, VPC Flow Logs, and Security Hub, providing continuous detection of suspicious and malicious activity across cloud environments.
			If this Question is set to Critical action plan to remediate it is mandatory

Mobile Application Security - Questions

Mobile Application Security - Questions	Answer	Risk Flag	Free Text Narrative	Action Plan
Are mobile applications developed following secure coding standards and subject to regular code reviews?			describe the options available	Evidence required
Is the application tested for known vulnerabilities using static and dynamic analysis tools (SAST/DAST)?			describe the options available	
Are mobile apps vetted for the use of insecure or unnecessary permissions (e.g., location, camera, contacts)?			describe the options available	
Is sensitive data stored by the app encrypted and protected from unauthorized access on the device?			describe the options available	Evidence required
Does the app validate server certificates and use secure communication protocols (e.g., TLS 1.2+) to prevent MITM attacks?			describe the options available	
Are apps signed and integrity-verified prior to deployment in app stores or enterprise distribution?			describe the options available	
Is there a process in place to rapidly patch mobile apps and notify users of critical vulnerabilities?			describe the options available	
Are external libraries and SDKs used in mobile apps tracked and vetted for security vulnerabilities?			describe the options available	
Is data leakage prevented through protections against clipboard access, screenshots, logging of sensitive fields, etc.?			describe the options available	
Are mobile apps tested against platform-specific threats (e.g., rooting/jailbreaking, insecure inter-app communication)?			describe the options available	

Technology-Specific - Questions

Does the supplier clearly define and document shared responsibility boundaries for security and compliance in cloud environments?

Compliant

Low

Teramot follows the AWS Shared Responsibility Model, with responsibilities clearly defined and documented between AWS (infrastructure and physical security) and Teramot (configuration, access control, data protection, monitoring, and compliance). These boundaries are documented within internal security policies, cloud architecture documentation, and compliance materials, ensuring clear accountability for security and regulatory controls.

Are baseline security configurations established and enforced for cloud workloads?

Compliant

Low

Baseline configurations are enforced using hardened AMIs, Infrastructure as Code (IaC), IAM guardrails, security groups, and network segmentation, aligned with CIS/NIST guidance.

Is sensitive customer data encrypted at rest and in transit within cloud services?

Compliant

Low

Data is encrypted at rest using AWS KMS-backed encryption and in transit using TLS (HTTPS) across all cloud services.

Are customer-managed encryption keys (CMKs) supported and available for data encryption?

Compliant

Low

AWS KMS CMKs are supported, allowing separation of duties and customer-specific key management where required.

Does the supplier perform regular vulnerability scanning and configuration compliance checks in cloud environments?

Compliant

Low

Continuous scanning is performed using AWS Inspector, dependency scanning, and configuration reviews, with findings tracked to remediation.

Is centralized logging and monitoring implemented for all cloud resources?

Compliant

Low

Logs are centralized using CloudWatch, CloudTrail, and Security Hub, providing unified visibility across cloud resources.

Are administrative access activities to cloud environments monitored and audited?

Compliant

Low

All administrative actions are logged via AWS CloudTrail, monitored, and retained for audit purposes.

Does the supplier have a defined process for security incident detection and response specific to cloud environments?

Compliant

Low

Cloud-specific incident detection and response is implemented using GuardDuty, EventBridge, CloudWatch alarms, and documented IR procedures.

Are multi-factor authentication (MFA) mechanisms enforced for administrative access to cloud environments?

Compliant

Low

MFA is mandatory for all privileged and administrative cloud access.

Is there a documented procedure for securely de-provisioning cloud resources and ensuring data sanitization upon termination?

Compliant

Low

De-provisioning follows documented procedures including resource teardown, access revocation, and encrypted data destruction via cloud-native mechanisms.

Does the supplier conduct third-party audits (e.g., SOC 2 Type II, ISO 27017) for their cloud environments?

Compliant

Low

Teramot is in the final stage of SOC 2 Type I, proceeding to SOC 2 Type II, and has initiated ISO/IEC 27001, with cloud controls in scope.

Are cloud service APIs secured against unauthorized access and vulnerabilities?

Compliant

Low

APIs are secured using IAM authentication, least privilege, TLS encryption, input validation, and monitoring.

Does the supplier identify and document the intended purpose, context, and scope of AI/ML systems?

Compliant

Low

AI/ML use cases are documented, defining purpose, scope, and operational context.

Are risks associated with AI/ML systems assessed, including bias, security vulnerabilities, and potential misuse?

Compliant

Low

AI/ML risks are assessed as part of security and risk management processes, including misuse and exposure risks.

Are mechanisms in place to ensure training datasets are protected against unauthorized access and tampering?

Compliant

Low

Datasets are protected using access controls, encryption, and audit logging.

Is there a process to validate the integrity and quality of datasets used for AI/ML training and testing?

Compliant

Low

Dataset validation and integrity checks are performed prior to use in training or testing.

Does the supplier monitor AI/ML models post-deployment for performance degradation, bias, or adversarial attacks?

Compliant

Low

Models are monitored for performance issues, anomalies, and misuse indicators as part of operational oversight.

Are human oversight mechanisms integrated into AI/ML decision-making processes, especially for high-impact outcomes?

Compliant

Low

Human review and oversight are applied for high-impact or sensitive outcomes.

Are AI/ML models versioned and changes documented systematically to enable traceability and reproducibility?

Compliant

Low

Models are versioned, and changes are documented to ensure traceability and reproducibility.

Does the supplier ensure transparency of AI/ML system functionalities and limitations to customers and stakeholders?

Compliant

Low

System functionality, limitations, and intended use are documented and communicated where applicable.

Security Architecture - Questions

Security Architecture - Questions	Answer	Risk Flag	Free Text Narrative
Do you implement continuous authentication and verification of users and devices to access resources?	Yes	Low	Access is continuously verified using centralized identity management, MFA enforcement, short-lived credentials, and session monitoring, with authentication events logged and evaluated in real time.
Are access decisions dynamically enforced based on user identity, device posture, location, and risk indicators?	Yes	Low	Access decisions are dynamically enforced using identity-based IAM policies, contextual signals (role, source, session state), and risk indicators from security monitoring services, with adaptive controls applied where required.
Is network segmentation in place to enforce least privilege access and to isolate critical resources?	Yes	Low	Network segmentation is implemented using VPC isolation, subnet separation, security groups, NACLs, and service-level boundaries, enforcing least-privilege access to critical resources.
Does the supplier utilize a policy decision point (PDP) and policy enforcement point (PEP) model for access control?	Yes	Low	Teramot implements an implicit PDP/PEP access control model through centralized identity and access management policies and distributed enforcement mechanisms. Access decisions (policy evaluation) are defined through documented Access Control and Security Policies and enforced at multiple layers including AWS IAM, network controls, and application-level authorization, ensuring consistent policy evaluation and enforcement across cloud resources. Link To Compliance Hub
Are user and device authentication logs monitored continuously for anomalies?	Yes	Low	Authentication logs are continuously monitored via CloudTrail, CloudWatch, and GuardDuty, with anomaly detection and alerting enabled.
Is there a process to continuously assess the trustworthiness of user devices before granting or maintaining access?	Yes	Low	Device trust is assessed using endpoint security posture, encrypted devices, OS-level controls, and access restrictions, with access limited to compliant devices.
Are applications and workloads treated as independent security zones regardless of network location?	Yes	Low	Applications and workloads are treated as independent security zones, with isolated IAM roles, network boundaries, and service-level controls, following Zero Trust principles.
Do you ensure that all traffic inside the network is authenticated and encrypted?	Yes	Low	All internal and external traffic is authenticated and encrypted using TLS, with encrypted service-to-service communication and secure network configurations.